EXP-010 · Autenticación y autorización de socios al solicitar una cotización

Resultados y análisis del experimento · HU5.1.1 / QS-018 (Seguridad · Resistencia)

ISIS-2212 Arquitecturas de software robustas · Sprint 2 · Grupo 7 · Génesis Beraly Parada Ventura · 12 de noviembre de 2026

1. Contexto del experimento

Funcionalidad de negocio. Un socio de distribución solicita desde su app una cotización para uno de sus clientes (`POST /v1/socios/cotizaciones`). El flujo involucra cuatro microservicios: AWS API Gateway (borde) → api-gateway interno (NestJS) → Distribución y socios → Cotización → Perfilamiento.

ASR (QS-018). Ante solicitudes sin token, con token alterado o expirado, sin el scope requerido o sobre clientes de otro socio, el sistema rechaza con 401/403 sin que las no autenticadas lleguen a los microservicios; las solicitudes válidas completan el flujo.

Hipótesis. Si un AWS API Gateway de borde (gateway de terceros) autentica a cada socio con un autorizador JWT de Amazon Cognito y verifica el scope `cotizaciones/crear` antes de reenviar al gateway interno, y Distribución y socios verifica que el cliente pertenece al socio del token antes de pedir la cotización, entonces el 100 % de las peticiones indebidas se rechaza con 401/403 —las no autenticadas o sin scope sin llegar al gateway interno ni a los microservicios— y el 100 % de las válidas completa el flujo con 201.

Tácticas bajo prueba

- **Autenticar actores en el borde:** OAuth2 *client_credentials* con Cognito; el autorizador JWT nativo de AWS API Gateway valida firma, emisor, vencimiento y audiencia (configuración, no código propio).
- **Autorizar actores por scope:** la ruta exige `cotizaciones/crear`.
- **Autorizar actores por pertenencia:** Distribución y socios identifica al socio con el `client_id` del token ya validado (propagado por el borde) y solo atiende clientes propios.
- **Limitar acceso (complementaria):** el gateway interno solo acepta peticiones con un encabezado secreto que agrega el borde (Secrets Manager).

Diseño de la prueba. Seis casos de 20 peticiones secuenciales cada uno, sin carga (el ASR es de seguridad, no de latencia), más una prueba de bypass de 5 peticiones. Variables controladas: misma infraestructura y datos semilla, limitador del EXP-008 apagado (`RATE_LIMIT_ENABLED=false`). Criterio: la hipótesis se confirma solo si el 100 % de las peticiones de cada caso recibe el código esperado **y** ninguna petición rechazada aparece en los logs de un componente que no debía alcanzar.

Entorno. Cuenta AWS propia, región us-east-2, desplegada con CloudFormation (`experimento/infra/exp010.yaml`): Cognito (4 app clients), AWS API Gateway HTTP API, ECS Fargate (4 servicios), 2 ALB, RDS PostgreSQL y Secrets Manager. Corrida ejecutada desde AWS CloudShell el 12-nov-2026 a las 03:09 UTC.

2. Resultados

2.1 Respuestas observadas por el socio

Caso	Descripción	Esperado	Aciertos	%	Quién rechaza
C1	Sin token	401	20/20	100	AWS API Gateway (borde)
C2	Token con la firma alterada	401	20/20	100	AWS API Gateway (borde)
C3	Token expirado	401	20/20	100	AWS API Gateway (borde)

Caso	Descripción	Esperado	Aciertos	%	Quién rechaza
C4	Token sin scope cotizaciones/crear	403	20/20	100	AWS API Gateway (borde)
C5	Socio A pide para un cliente del socio B	403	20/20	100	Distribución y socios
C6	Socio A pide para su propio cliente	201	20/20	100	— (llega a Cotización)
C7	Bypass: directo al gateway interno	403	5/5	100	api-gateway interno



Figura 1. Peticiones con el código esperado por caso (verde) frente a código distinto (rojo; ninguna).

2.2 Qué vio cada componente (CloudWatch Logs Insights)

Para verificar *dónde* se detuvo cada petición se contaron, en la ventana de la corrida, los registros de acceso del AWS API Gateway (campo `integrationStatus`: vacío significa que el borde no invocó al gateway interno) y los eventos JSON que emiten el gateway interno, Distribución y socios y Cotización.

Verificación	Esperado	Obtenido	Cumple
AWS API Gateway: 401 sin invocar la integración (C1–C3)	60	60	sí
AWS API Gateway: 403 por scope sin invocar la integración (C4)	20	20	sí
AWS API Gateway: reenviadas que terminaron en 403 (C5)	20	20	sí
AWS API Gateway: reenviadas que terminaron en 201 (C6)	20	20	sí
Gateway interno: peticiones recibidas desde el borde (solo C5 y C6)	40	40	sí
Gateway interno: bypass rechazado por falta del secreto de origen	5	5	sí
Distribución y socios: peticiones recibidas (solo C5 y C6)	40	40	sí
Distribución y socios: 403 por cliente de otro socio (C5)	20	20	sí
Distribución y socios: llamadas a Cotización (solo C6)	20	20	sí
Cotización: POST /cotizaciones recibidos (solo C6)	20	20	sí

Veredicto del analizador: hipótesis CONFIRMADA (17 de 17 verificaciones cumplidas: 7 casos y 10 conteos de logs, sin desviaciones).

2.3 Evidencia de la ejecución en AWS

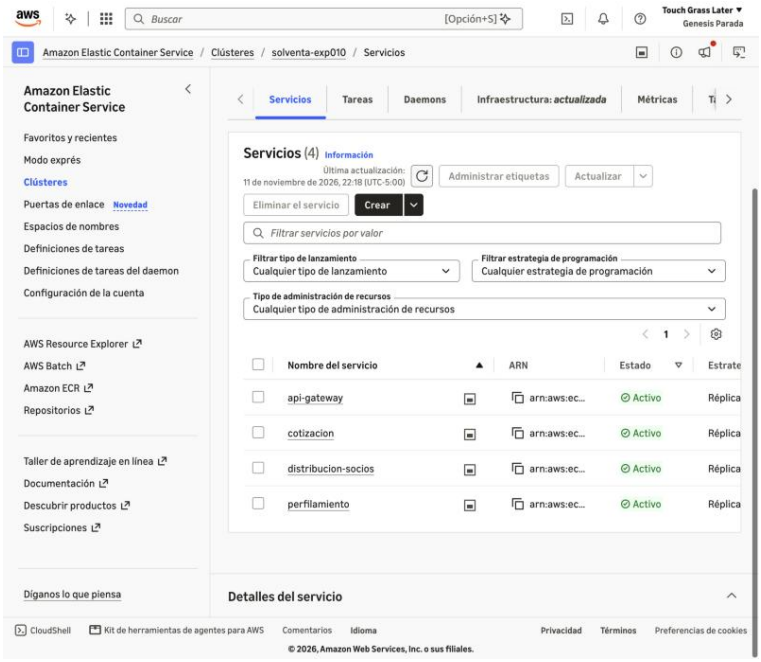


Figura 2. Clúster ECS solventa-exp010 con los 4 microservicios activos (api-gateway, cotizacion, distribucion-socios, perfilamiento).

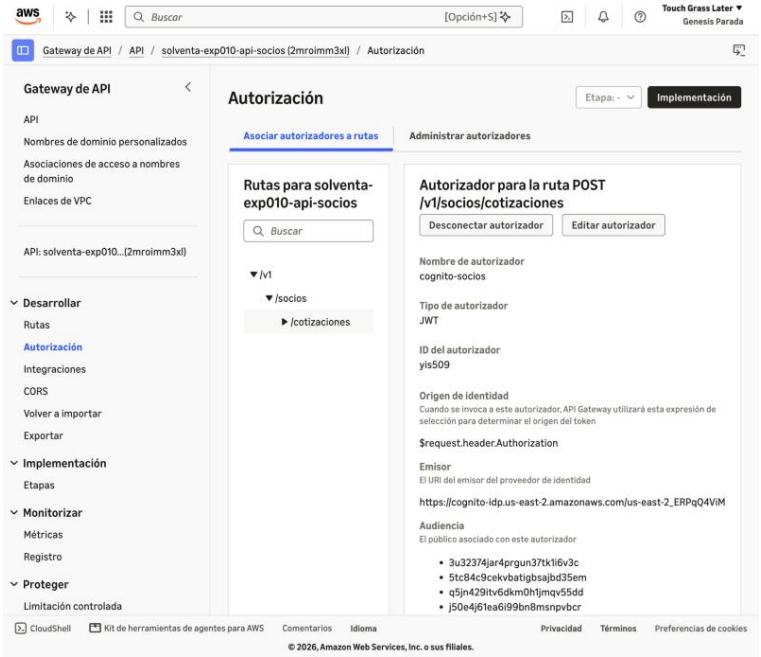


Figura 3. Autorizador JWT cognito-socios asociado a POST /v1/socios/cotizaciones: origen de identidad, emisor (user pool de Cognito) y audiencia (app clients de los socios).

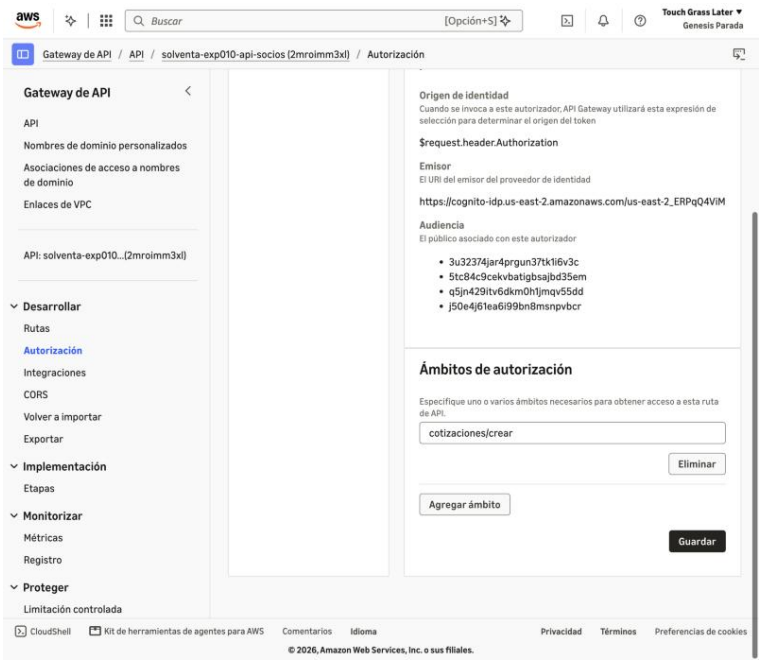


Figura 4. Ámbito de autorización exigido por la ruta: cotizaciones/crear.

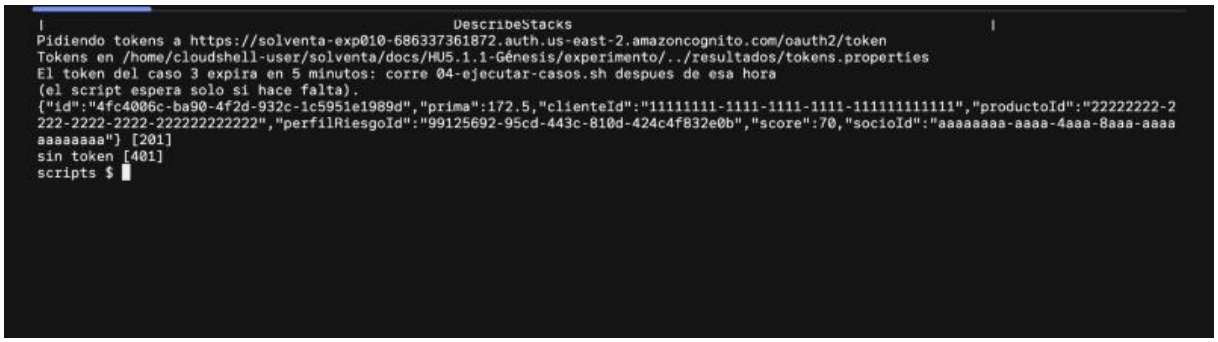


Figura 5. Prueba de humo previa: con token válido el flujo completo responde 201 con la cotización (prima 172.5, socioId del socio A); sin token, 401.

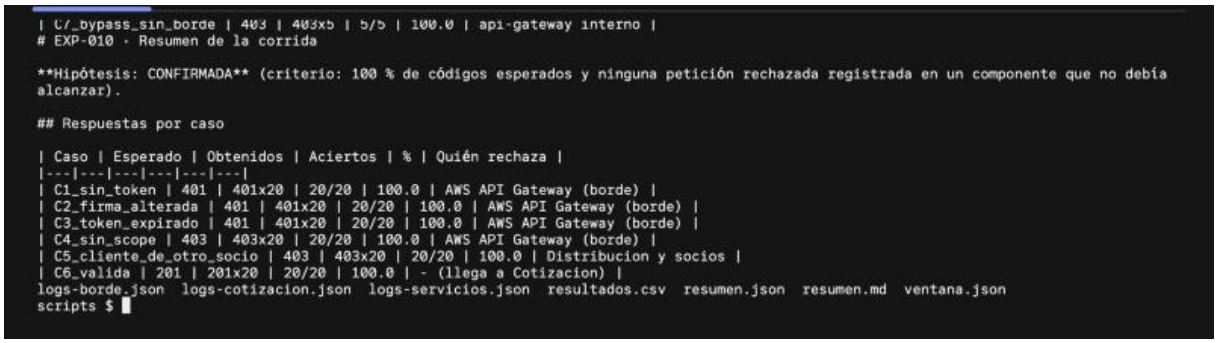


Figura 6. Salida del analizador en CloudShell: veredicto y respuestas por caso.

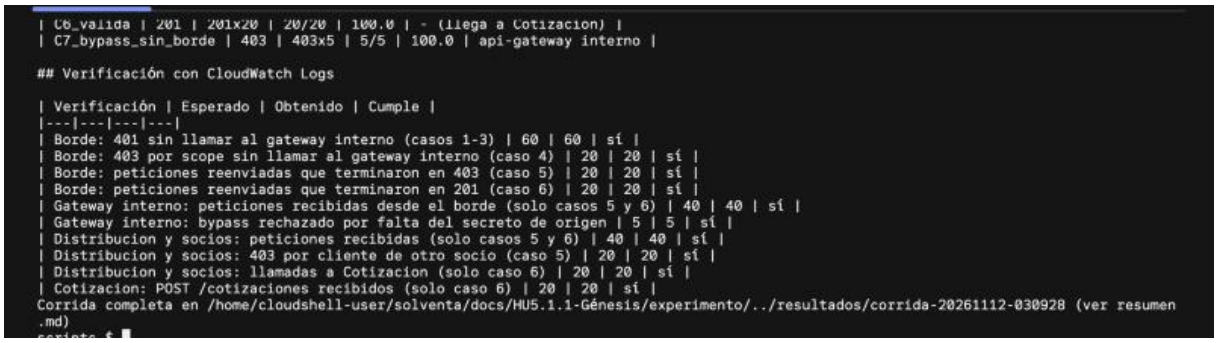


Figura 7. Salida del analizador: verificación cruzada con CloudWatch Logs.

3. Análisis

3.1 Lectura de los resultados a la luz de las tácticas

Autenticar actores en el borde (C1–C3). Las 60 peticiones sin token, con firma alterada o con token vencido recibieron 401 y el registro de acceso muestra que el AWS API Gateway no invocó la integración en ninguna. El gateway interno registró exactamente 40 peticiones reenviadas, que corresponden solo a C5 y C6. Esto confirma la propiedad central del diseño en dos niveles: la verificación criptográfica del token ocurre en un componente administrado y de terceros, antes del primer salto hacia la red de los microservicios, sin código propio de validación.

Autorizar por scope (C4). El token del socio A sin el scope `cotizaciones/crear` es auténtico, por lo que el rechazo no puede atribuirse a la autenticación: el 403 lo produce la regla de autorización de la ruta. Las 20 peticiones se detuvieron en el borde. La distinción 401/403 que entrega AWS coincide con la semántica esperada (no autenticado frente a no autorizado).

Autorizar por pertenencia (C5). Es el caso que el borde no puede resolver: el token es válido y tiene el scope, pero el cliente es de otro socio. Las 20 peticiones llegaron a Distribución y socios, que respondió 403 sin llamar a Cotización (Cotización registró solo 20 POST, todos de C6). Esto muestra que la autorización de grano grueso (scope) y la de grano fino (dato de negocio) son complementarias y se ubican donde está la información necesaria para decidir.

Camino válido (C6). Las 20 peticiones completaron la cadena de cuatro microservicios con 201 y la prima esperada (172.5 = 150 × 1.15 por score 70), lo que descarta que los rechazos se deban a un sistema que simplemente falla: el mismo despliegue sirve correctamente a los actores legítimos.

Limitar acceso (C7, bypass). Una petición que intenta saltarse el borde llamando directo al ALB del gateway interno, aun con un `x-socio-client-id` falsificado del socio A, recibe 403 por no traer el secreto de origen. Sin esta táctica, la identidad propagada por encabezado sería suplantable.

3.2 Explicaciones alternativas consideradas

- **¿Los 401/403 podrían venir de un error de configuración o de servicios caídos?** No: C6 se ejecutó en la misma ventana con 201 en el 100 % y los cuatro servicios estaban activos (Figura 2); además, el 401 y el 403 provienen de componentes distintos según el caso, como predice el diseño.
- **¿El 403 de C5 podría deberse al scope y no a la pertenencia?** No: C5 usa el mismo token que C6 (scope válido) y sí llegó a Distribución y socios, que registró el motivo `cliente_de_otro_socio`.
- **¿Un 429 del limitador del EXP-008 podría confundirse con un rechazo?** Se controló apagando el limitador; no se observó ningún 429.

- **¿El token del caso 3 podría no haber estado vencido?** El script esperó más de 5 min 30 s tras emitirlo (validez configurada de 5 minutos) antes de iniciar la corrida.

3.3 Amenazas a la validez

- **Validez externa (tamaño y variedad):** 20 peticiones por caso y un solo tipo de alteración de firma. No se probaron ataques como *alg=none*, tokens de otro emisor o reutilización entre audiencias; la mitigación es que esa validación la realiza un servicio administrado de AWS, pero no se midió aquí.
- **Entorno:** una sola corrida, en una cuenta propia en us-east-2 y no en AWS Academy; los resultados de seguridad no dependen de la región, pero sí de la configuración, que está versionada en la plantilla.
- **Medición indirecta en logs:** la verificación de “no llegó” se basa en conteos de CloudWatch en una ventana de tiempo; una petición fuera de la ventana podría no contarse. Se mitigó esperando 60 s antes de consultar y cruzando conteos que deben coincidir exactamente (40/40, 20/20).
- **Secreto de origen estático:** el encabezado secreto queda en la configuración del API Gateway; si se filtra, el bypass sería posible. Una evolución es usar un VPC Link con ALB interno (sin exposición pública) o mTLS entre borde y gateway interno.
- **Costo en latencia:** el diseño agrega un salto de red; no se midió porque el ASR es de seguridad. Para experimentos de latencia del equipo debe considerarse.

4. Conclusión

La hipótesis se confirma. En los seis casos el 100 % de las peticiones recibió el código esperado (60 × 401, 40 × 403 y 20 × 201) y la verificación con CloudWatch mostró que ninguna petición rechazada alcanzó un componente que no debía: las de autenticación y scope se detuvieron en el AWS API Gateway de borde, la de pertenencia en Distribución y socios sin tocar Cotización, y el bypass en el gateway interno. Esto satisface la medida del QS-018 (100 % de solicitudes indebidas rechazadas sin llegar a los microservicios y 100 % de las válidas atendidas).

Arquitectónicamente, el experimento respalda la decisión de ubicar la autenticación y la autorización por scope en un gateway de terceros (atendiendo la observación de la profesora) y la autorización de negocio en el microservicio dueño del dato, manteniendo el gateway interno del equipo sin cambios para el EXP-008. Como evolución se propone consolidar en el gateway administrado también la cuota por socio (*usage plans*) y reemplazar el ALB público del gateway interno por un VPC Link privado.

5. Reproducibilidad

Código en la rama `exp010-genesis`: `services/distribucion-socios/src/exp010/`, `services/api-gateway/src/socios-cotizaciones.controller.ts` (todo detrás de `JWT_VALIDATION_ENABLED`). Infraestructura, scripts (01–06) y analizador en `docs/HU5.1.1-Génesis/experimento/`; resumen de esta corrida en `docs/HU5.1.1-Génesis/resultados/corrida-20261112-030928/`.